



HA NOI UNIVERSITY OF SCIENCE AND TECHNOLOGY
SCHOOL OF INFORMATION AND COMMUNICATION TECHNOLOGY

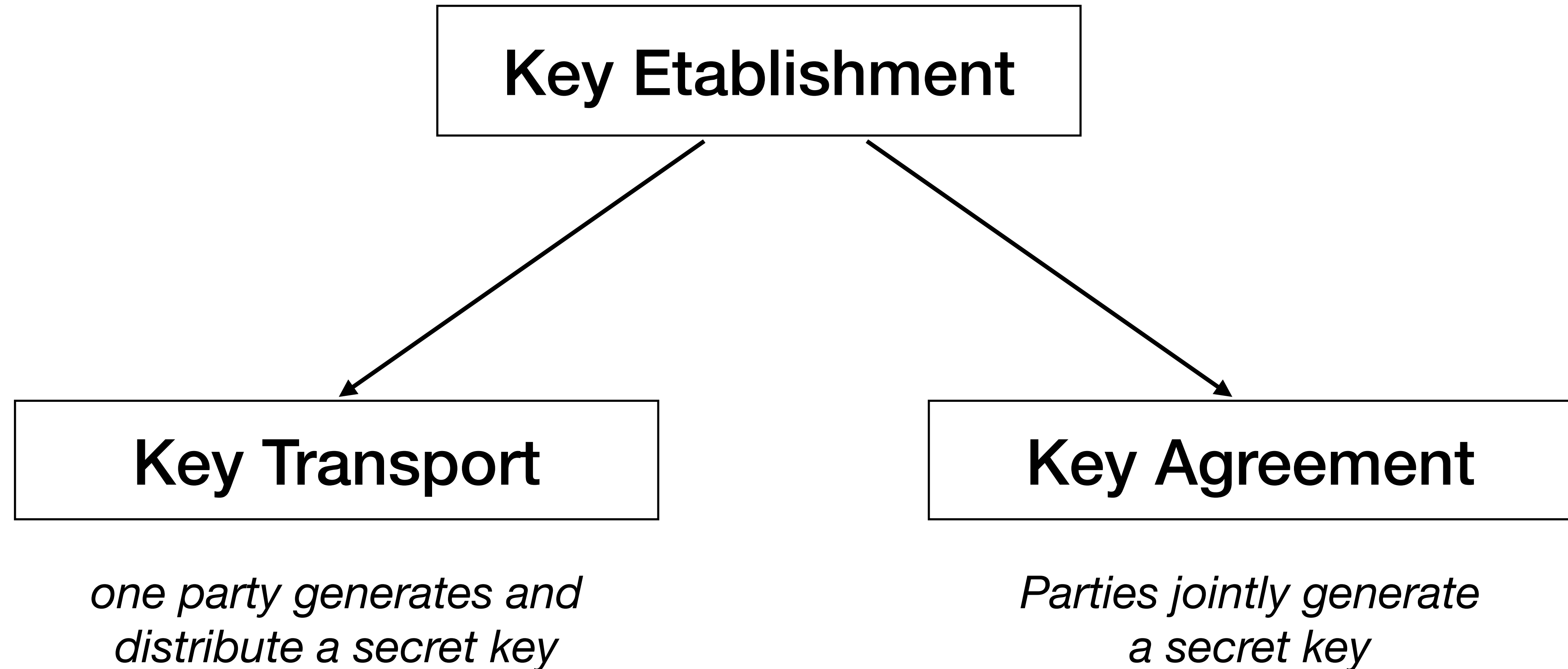
Introduction to Cryptography and Security

Key Establishment

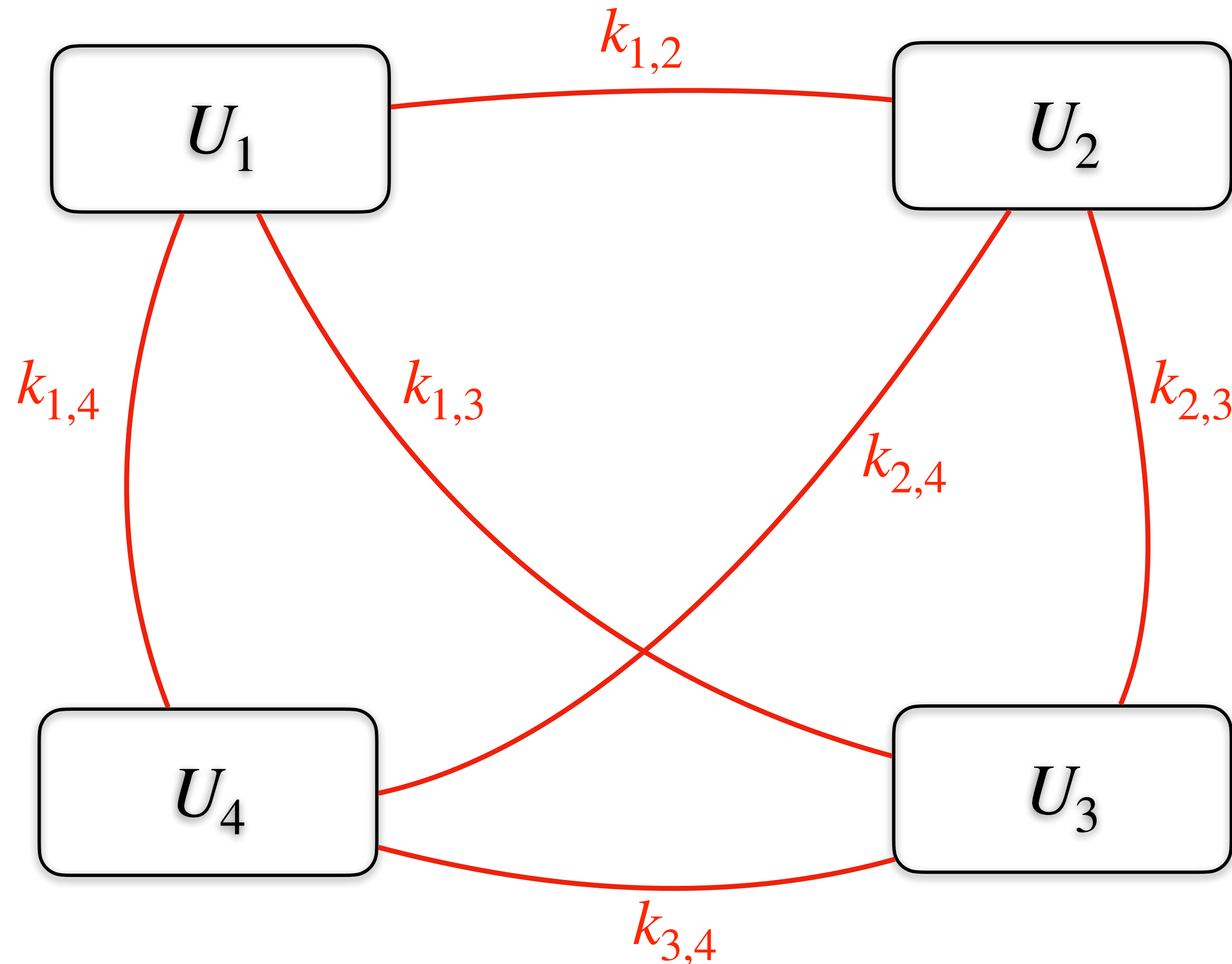
Contents

- **Introduction**
- Key Establishment Using Symmetric-Key Techniques
- Key Establishment Using Asymmetric Techniques
- Public-Key Infrastructures (PKIs) and CAs

Classification of key establishment schemes



The n^2 Key Distribution Problem



The n^2 Key Distribution Problem: Draw Backs

- Large number of key (quadratic):
 - # keys: $n \times (n - 1)$
 - # key pairs: $n \times (n - 1)/2$
 - Ex. Company with 750 people = 280875 key pairs
- Adding new users is complex

Contents

- Introduction
- **Key Establishment Using Symmetric-Key Techniques**
- Key Establishment Using Asymmetric Techniques
- Public-Key Infrastructures (PKIs) and CAs

Key Establishment Using a Key Distribution Center

Alice

k_A

KDC

k_A, k_B

Bob

k_B

RQST (ID_A, ID_B)



Generate random k_{ses}

$$y_A = E(k_A, k_{ses})$$

$$y_B = E(k_B, k_{ses})$$

y_A, y_B



$$k_{ses} = D(k_A, y_A)$$

$$y = E(k_{ses}, x)$$

y, y_B



$$k_{ses} = D(k_B, y_B)$$

$$x = D(k_{ses}, y)$$

KDC Protocols

- Idea: Center “trusted authority” KDC that shares one key with every user.

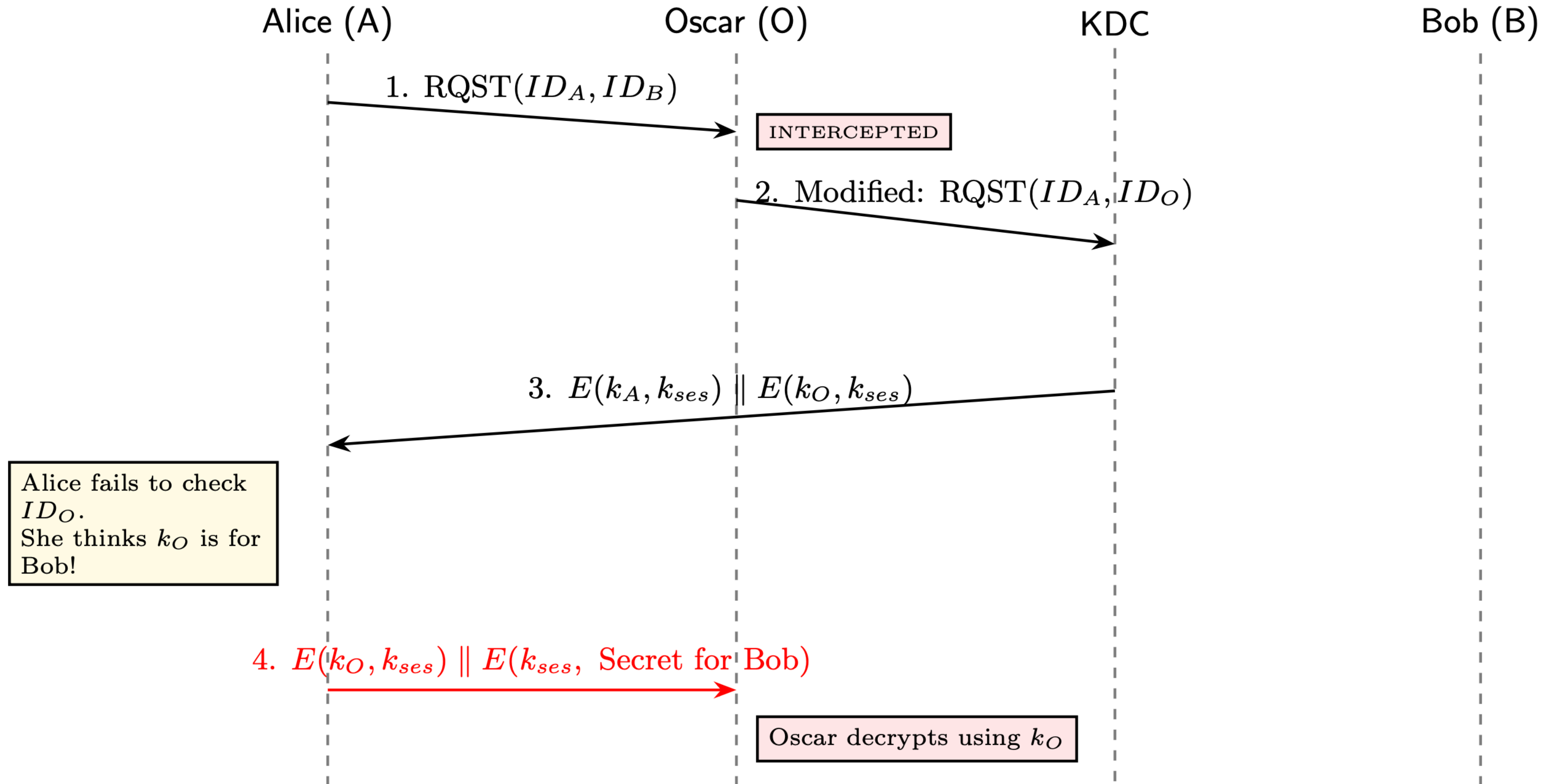
Advantage

- Adding a new user only requires secure Channel KDC $\leftrightarrow$ user at initialization time.
- k_A , k_B , k_C are called “key encryption keys” (KEKs)

Weaknesses

- KDC is a single point of failure
- No “Perfect Forward Secrecy” (PFS) if they KEKs are compromised all past communication can be decrypted.

Key Confirmation Attack



Notations

- $X \rightarrow Y: \{Z \parallel W\} k_{XY}$
X sends Y the message produced by concatenating Z and W enciphered by key k_{XY} which is shared by users X and Y
- $A \rightarrow T: \{Z\} k_A \parallel \{W\} k_{AT}$
A sends T a message consisting of the concatenation of Z enciphered using k_A , A's key, and W enciphered using k_{AT} , the key shared by A and T
- r_A, r_B nonces (nonrepeating random numbers)

Needham-Schroeder Protocol

1. $A \rightarrow S: A, B, r_A$

2. $S \rightarrow A: \{r_A \parallel B \parallel k_{ses} \parallel \underbrace{\{k_{ses} \parallel A\} k_{BS}}_{\text{ticket for Bob}}\} k_{AS}$

3. $A \rightarrow B: \{k_{ses} \parallel A\} k_{BS}$

4. $B \rightarrow A: \{r_B\} k_{ses}$

5. $A \rightarrow B: \{r_b - 1\} k_{ses}$ // 4 & 5 prove both parties hold k_{ses} live

Freshness & Mutual Authentication

- *Alice's Freshness (r_A)*: Alice sends a nonce to the KDC; its encrypted return proves the session key k_{ses} is new, not a replay.
- *Bob's Freshness (r_B)*: Bob sends a nonce to Alice; she returns $r_B - 1$. This "Challenge-Response" proves Alice is active and holds the key.
- *Identity Binding*: The KDC includes ID A and ID B in encrypted packets to ensure the key is only used by the intended pair.

The Replay Attack Vulnerability

- *The Flaw:* Bob cannot verify if the message from the KDC is "fresh" or a replay of an old session.
- *The Attack:*
 1. Oscar steals an old session key and its KDC-encrypted message.
 2. Oscar replays that encrypted message to Bob.
 3. Bob accepts the old key and completes the nonce handshake with Oscar.
- *Outcome:* Bob believes he is talking to Alice, but he is communicating with an attacker.

No Perfect Forward Secrecy (PFS)

- *Definition:* A system has PFS if compromising long-term keys does not expose past session keys.
- *The Issue:* Needham-Schroeder uses static Key Encryption Keys (KEKs) to distribute session keys.
- *Consequences:* If a user's KEK is compromised:
 - *Future:* Attackers can decrypt all new keys.
 - *Past:* Attackers can decrypt recorded historical traffic.

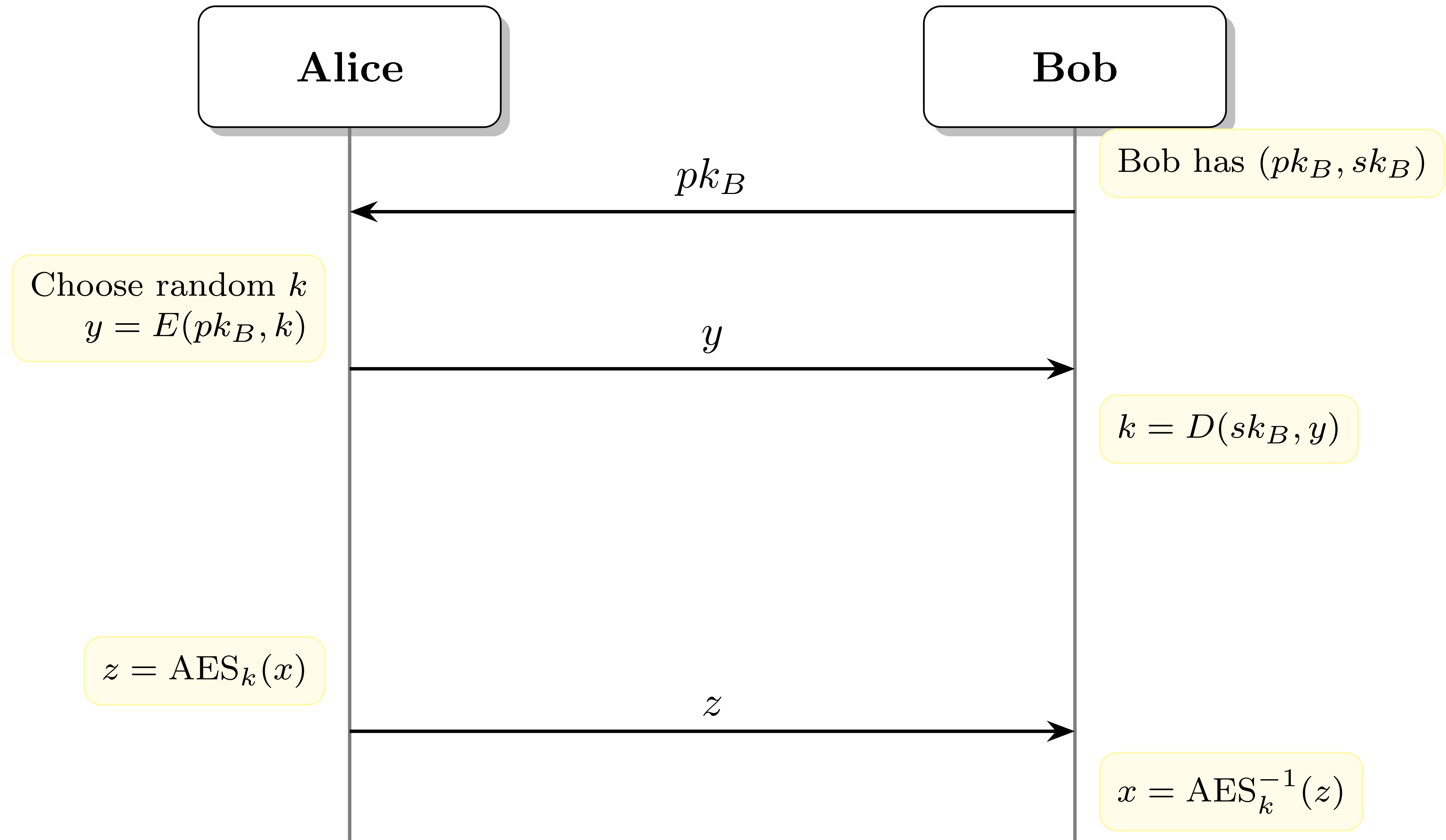
KDC Operational Bottlenecks

- *Single Point of Failure:* If the KDC database is breached, every user's key is compromised.
- *Initialization:* Requires a pre-existing “secure channel” (e.g., physical exchange) for a new user to receive their first KEK.
- *Performance:* The KDC is a bottleneck; it must be contacted for every new session initiation.
- *Scale:* While used in corporate environments (Kerberos), it cannot scale to billions of global internet users.

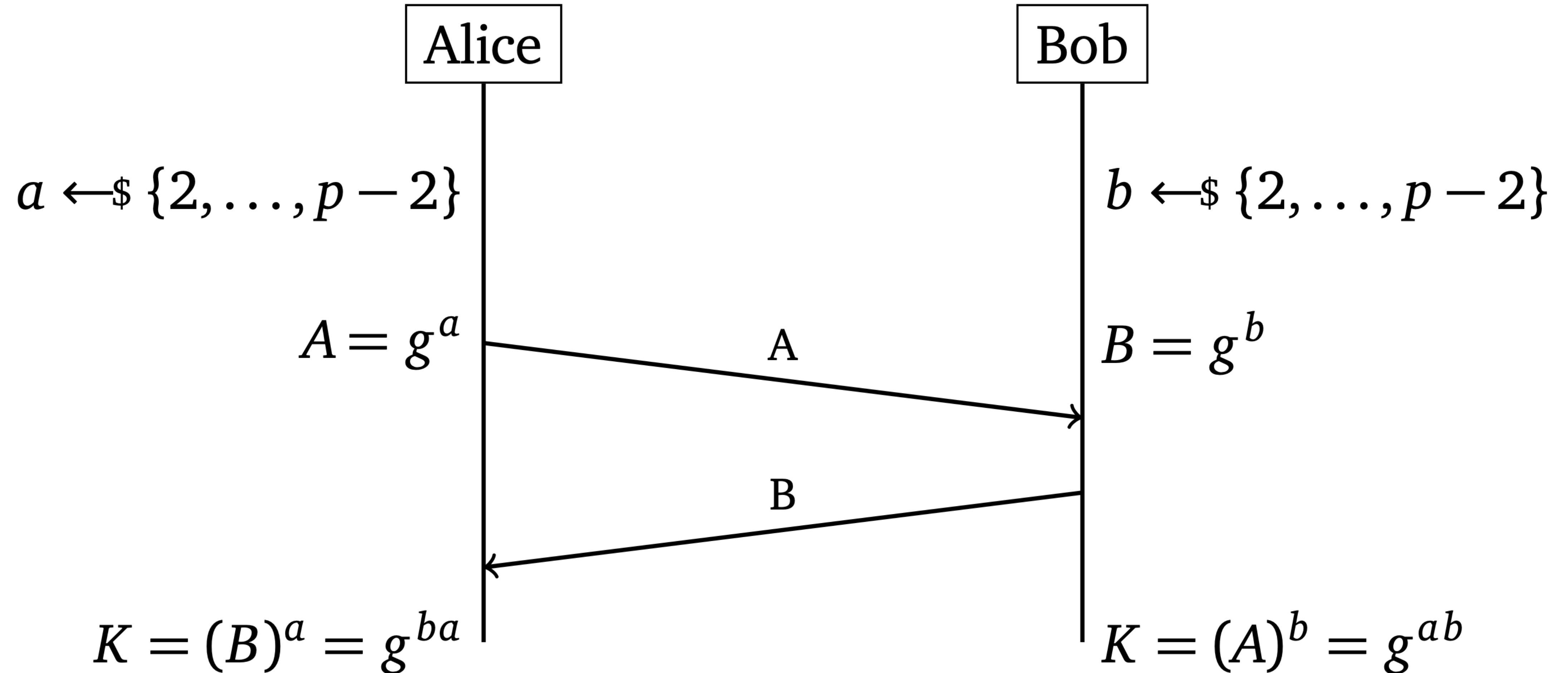
Contents

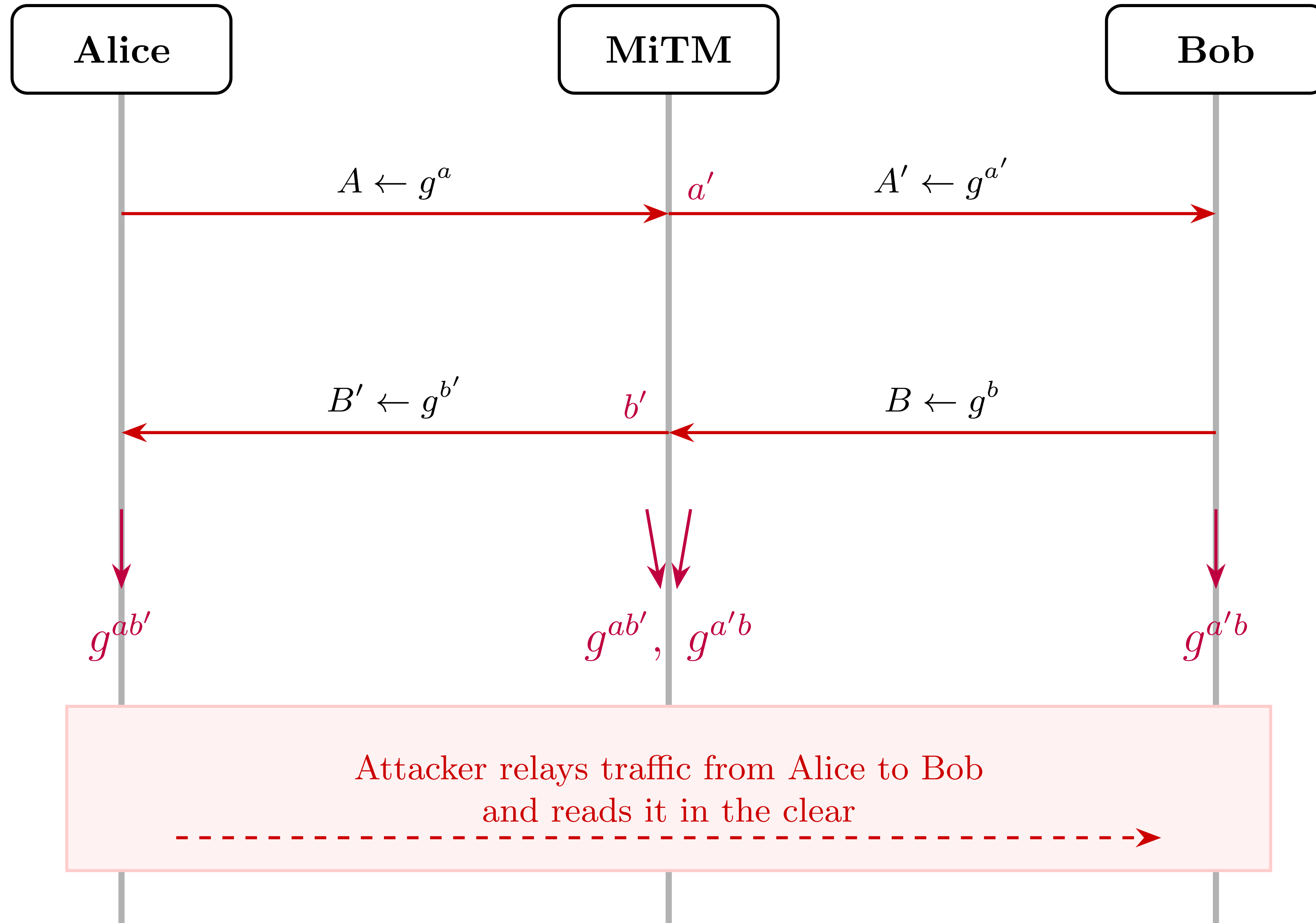
- Introduction
- Key Establishment Using Symmetric-Key Techniques
- **Key Establishment Using Asymmetric Techniques**
- Public-Key Infrastructures (PKIs) and CAs

Basic Key Transport Protocol



DH Key Exchange





Man-in-the-middle Attack

Public Key Distribution & Certificates

The Problem

- Distributing public keys insecurely is vulnerable to active attacks (e.g., Man-in-the-Middle).
- *Solution*: Use Certificates (issued by the CA) to authenticate the key owner.

Certificate Structure

- A certificate binds a user's identity to their public key using a digital signature:

$$Cert_A = \underbrace{[pk_A \parallel ID_A]}_{\text{payload}} \parallel \underbrace{\text{sign}(sk_{CA}, pk_A \parallel ID_A)}_{\text{Protects the payload against manipulation}}$$

Verification Process

1. Receiver gets $Cert_A$.
2. Receiver uses the CA's trusted public key to verify the signature.
3. If valid, the receiver trusts that pk_A belongs to ID_A .

Certificate Authority

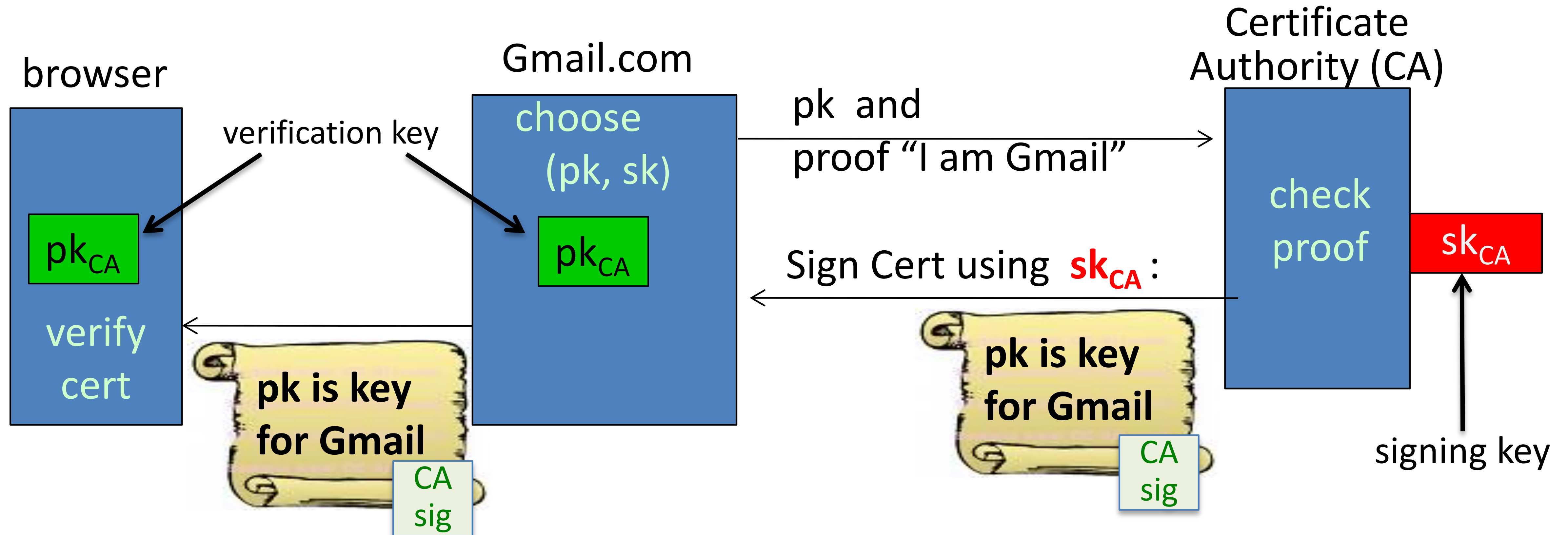
The Trust Model

- To solve the key authentication problem, we rely on a Mutually Trusted Third Party.
- This party is called the Certificate Authority (CA).

Role & Responsibilities

- Trust Anchor: The CA's public key is known and trusted by all parties in the system.
- Issuance: The CA verifies the identity of users (e.g., Alice) and generates digital certificates for them.
- Significance: Without a trusted CA, we cannot securely verify the ownership of a public key.

Example



Server uses Cert for an extended period (e.g. one year)

X.509 Certificates Overview

Definition & Context

- *Standard*: X.509 is the dominant standard for public key certificates.
- *Usage*: Essential for TLS/SSL, IPsec, and S/MIME.

Cryptographic Composition

- A certificate involves two distinct algorithm sets:
- *Subject's Algorithm*: The algorithm of the public key being certified (e.g., ECDH 256-bit).
- *Signature Algorithm*: The algorithm used by the CA to sign the certificate (e.g., RSA 2048-bit with SHA-256).

X.509: Key Fields

FIELD	DESCRIPTION	PURPOSE / NOTES
Subject	Identity of the owner (User/Org)	Matches the ID_A in theoretical models.
Issuer	The Certificate Authority (CA)	The entity that generated and signed the certificate.
Validity	Start & Expiration Date	Limits risk if keys are compromised or employees leave.
Public Key	Binary key value & parameters	Includes algorithm details (e.g., modulus p , generator g).
Signature	CA's digital signature	Ensures integrity of all fields listed above.

Certificates: example

Serial Number	5814744488373890497	←
Version	3	
Signature Algorithm	SHA-1 with RSA Encryption (1.2.840.113549.1.1.5)	
Parameters	none	
Not Valid Before	Wednesday, July 31, 2013 4:59:24 AM Pacific Daylight Time	
Not Valid After	Thursday, July 31, 2014 4:59:24 AM Pacific Daylight Time	
Public Key Info		
Algorithm	Elliptic Curve Public Key (1.2.840.10045.2.1)	
Parameters	Elliptic Curve secp256r1 (1.2.840.10045.3.1.7)	
Public Key	65 bytes : 04 71 6C DD E0 0A C9 76 ...	←
Key Size	256 bits	
Key Usage	Encrypt, Verify, Derive	
Signature	256 bytes : 8A 38 FE D6 F5 E7 F6 59 ...	←

Equifax Secure Certificate Authority
↳ GeoTrust Global CA
↳ Google Internet Authority G2
↳ mail.google.com

 **mail.google.com**
Issued by: Google Internet Authority G2
Expires: Thursday, July 31, 2014 4:59:24 AM Pacific Daylight Time
✔ This certificate is valid

▼ Details

Subject Name	
Country	US
State/Province	California
Locality	Mountain View
Organization	Google Inc
Common Name	mail.google.com ←
Issuer Name	
Country	US
Organization	Google Inc
Common Name	Google Internet Authority G2

Contents

- Introduction
- Key Establishment Using Symmetric-Key Techniques
- Key Establishment Using Asymmetric Techniques
- **Public-Key Infrastructures (PKIs) and CAs**

Public-Key Infrastructure (PKI)

Definition

- The entire system formed by CAs together with necessary support mechanisms.
- Manages public-key encryption in the real world.

Key Challenges

- *Identity Establishment:* Reliably verifying users before issuing certificates.
- *Key Distribution:* Trusted distribution of CA keys to users.
- *Scale & Management:* Handling many different CAs and certificate revocation.

Certificate Chains & Cross-Certification

The Problem

- No single global CA exists; users cannot store public keys for every CA in the world.

The Solution: Chain of Trust

- If Alice trusts CA1, and CA1 signs the key of CA2, then Alice can trust certificates issued by CA2.

$$Cert_{CA2} = \underbrace{[pk_{CA2} \parallel ID_{CA2}]}_{\text{payload}} \parallel \underbrace{\text{sign}(sk_{CA1}, pk_{CA2} \parallel ID_{CA2})}_{\text{Protects the payload against manipulation}}$$

- This creates a Certificate Chain, allowing verification even if the issuer is not directly known.

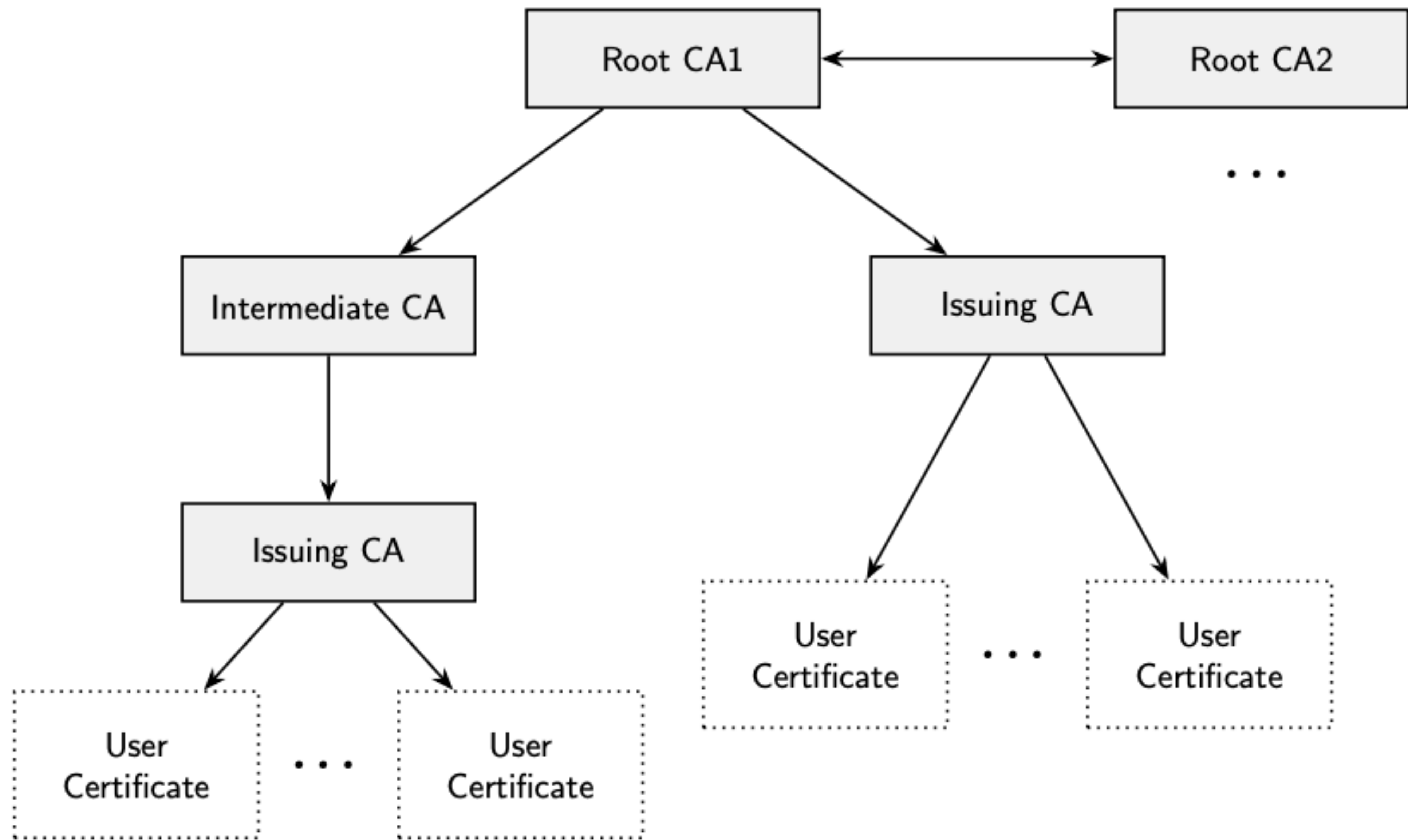
CA Hierarchy

Hierarchical Structure

- Root CA: The “Trust Anchor”. Typically kept offline to minimize risk. Only signs underlying CAs.
- Intermediate CA: Often used to reduce direct dependency on the Root CA.
- Issuing CA: Generates actual user certificates. Exposed to the network.

Security Benefits

- Compromised Issuing CAs can be revoked by the Root CA without breaking the whole system.
- Users verify the entire chain up to the Root CA.



Certificate Revocation

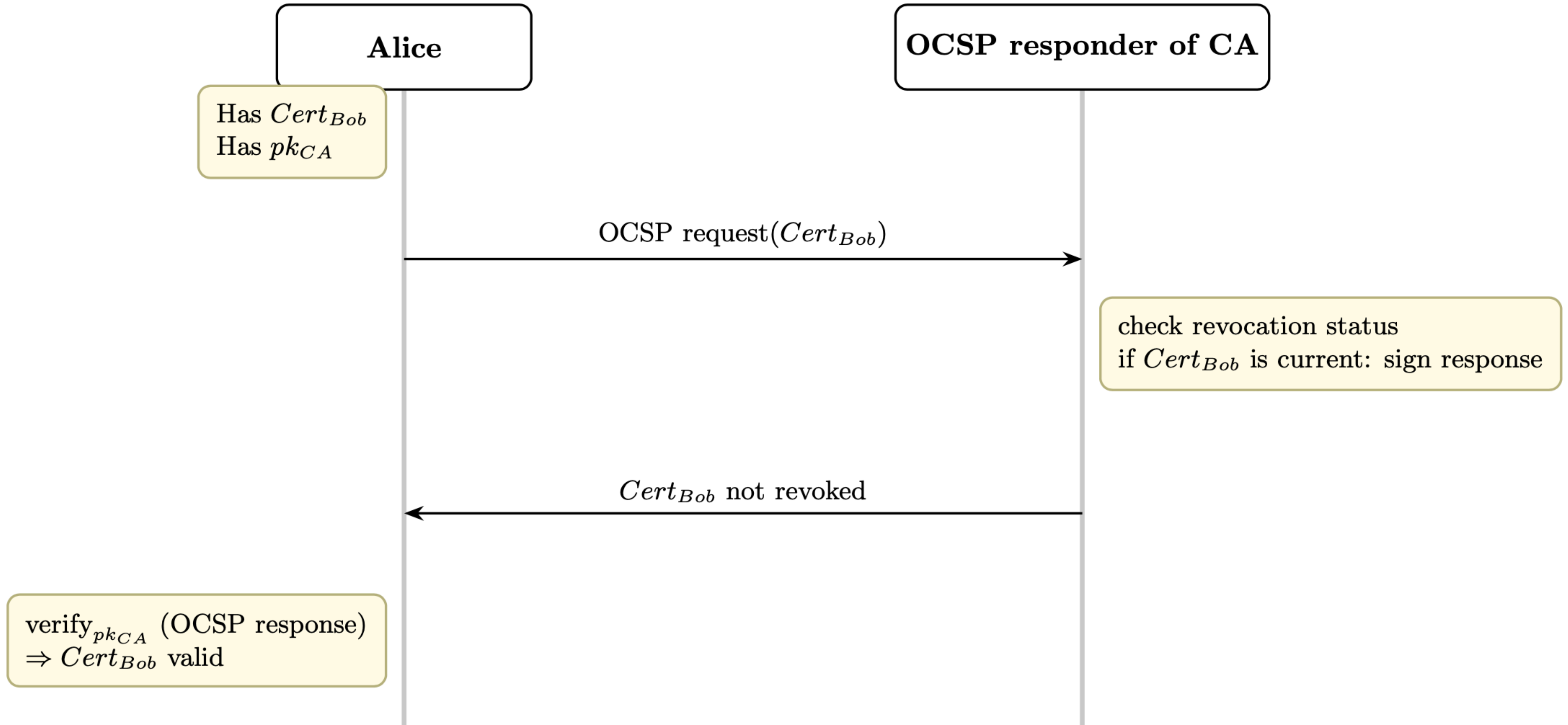
- Private keys are compromised (e.g., lost smart card).
- Users leave the organization.

Certificate Revocation 1: CRL

- Certificate Revocation Lists (CRL)
- A signed list containing serial numbers of invalid certificates.
- Distribution Issues:
 - *On-demand*: Creates a bottleneck.
 - *Periodic*: Creates a “validity gap” between updates.
- Delta CRLs: Optimization that sends only changes to save bandwidth.

Certificate Revocation 2: OCSP

- Online Certificate Status Protocol (OCSP): RFC 6960.
- *Function*: Determines certificate status in real-time without downloading full CRLs.
- **Process**
 1. OCSP Client: Sends a status request (with serial number) to the Responder.
 2. OCSP Responder: Replies with current status immediately.
- *Advantages*: Removes the “validity gap” of periodic CRLs and Reduces network bandwidth usage.



Certificate Revocation: OCSP



25 YEARS ANNIVERSARY
SOICT

VIỆN CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG
SCHOOL OF INFORMATION AND COMMUNICATION TECHNOLOGY

